

Capitolo 4

Metamodello della documentazione e regole di authoring DDTA

Stato del capitolo - revisione S1R1

La versione repository di questo capitolo è presente al commit DDTA 3eeac1fc972d89282cd2ffd8700e9af0f5b69610 e descrive la closure documentale fino al FunctionalRequirement. Questa revisione di lavoro del 14 agosto 2026 integra due risultati successivi: la chiusura semantica S1 di *Specialized Requirement* e la regressione del corpus facial-access che ha messo in discussione MR-0004. La regressione non introduce l'invariante "ogni MR deve essere connesso"; aggiunge invece una heuristic di authoring e tool-assisted review per i MacroRequirement isolati.

4.1 Scopo del capitolo

La Documentation-Driven Threat Analysis (DDTA) assume che la documentazione governata di un progetto possa costituire una sorgente di conoscenza stabile, strutturata e tracciabile per analisi successive. Prima di definire un modello analitico è quindi necessario stabilire come la conoscenza progettuale debba essere scritta, organizzata e progressivamente specializzata.

Il problema affrontato in questo capitolo è anteriore al threat modeling vero e proprio. Non si chiede ancora quali minacce identificare o quale metodologia applicare. Si chiede quale struttura documentale consenta di governare:

- il problema generale affrontato dal progetto;
- le macro-responsabilità necessarie a trattarlo;
- le scelte che restringono lo spazio delle soluzioni;

- i comportamenti operativi che devono risultare da tali scelte;
- gli obblighi concern-specific che rafforzano i comportamenti senza sostituirli;
- identità e relazioni riusabili nelle fasi successive senza duplicazione semantica.

Il percorso principale è normalizzato come:

```
Project problem framing      [method precondition]
  -> Macro Requirement
  -> Decision
  -> Functional Requirement
  -> Specialized Requirement
      -> concrete specialization
```

Per il perimetro della tesi, la specializzazione concreta studiata end-to-end sarà *Security Requirement*. Il contratto generale di *Specialized Requirement* rimane però metodologicamente neutro: tecniche differenti possono motivare specializzazioni relative a sicurezza, prestazioni o obblighi normativi/compliance senza richiedere MacroRequirement dedicati alla metodologia.

4.2 Separazione tra semantica, rappresentazione e tooling

DDTA separa quattro livelli per evitare che la serializzazione corrente o lo strumento diventino autorità semantica.

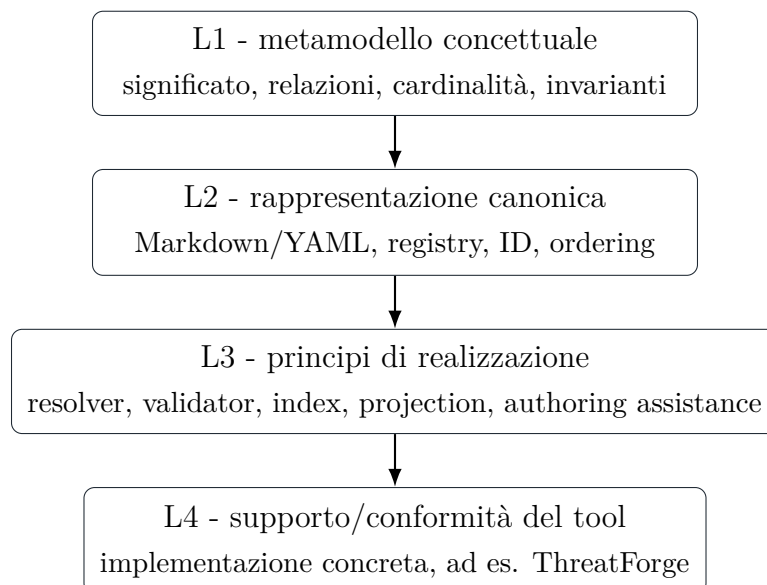


Figura 4.1: Separazione tra semantica, rappresentazione, realizzazione e tooling.

Una regola non appartiene al metamodello soltanto perché uno strumento può implementarla. Il test di sostituibilità rimane: se il tool venisse sostituito, la proprietà continuerebbe a descrivere il progetto governato? In caso affermativo è candidata a L1/L2; altrimenti appartiene più probabilmente a L3/L4.

4.3 Problem framing come preconditione metodologica

4.3.1 Perché il modello non parte direttamente dagli MR

Un *Macro Requirement* può diventare accidentalmente una descrizione della soluzione corrente. Formulare un progetto come “sistema di riconoscimento facciale con telecamera e modello ML” incorpora già scelte che potrebbero essere alternative a badge, impronta o provider esterno. Se tali scelte entrano nell'MR, la gerarchia non rende più visibile dove e perché lo spazio delle soluzioni è stato ristretto.

DDTA introduce quindi un passo di *problem framing* prima della decomposizione in documenti governati. Il framing non è un nuovo tipo di documento canonico nella baseline corrente.

Quale problema generale o classe di problemi deve affrontare il progetto, entro quale confine significativo, se rimuoviamo temporaneamente le scelte di soluzione correnti?

Il framing deve usare vocabolario del problema e del dominio. Provider, database, algoritmi, framework, device o metodologie di analisi vengono rimossi salvo che siano intrinseci al problema stesso.

4.3.2 Funzioni del framing

Il framing stabilisce un confine condiviso, consente di controllare coverage e overlap degli MR, crea un riferimento per riconoscere solution-vocabulary leakage e migliora la teachability. Non aggiunge un livello documentale: impedisce che il primo livello governato contenga già informazioni che dovrebbero emergere come scelte.

4.4 Gerarchia documentale progressiva

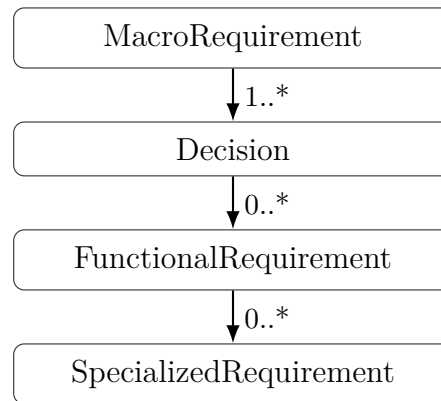


Figura 4.2: Gerarchia documentale progressiva della baseline DDTA.

La gerarchia rappresenta contenimento semantico, non il parsing di un ID o di una cartella. Le relazioni parentali devono essere esplicite e validabili anche se cambia la rappresentazione L2.

4.5 Macro Requirement

4.5.1 Definizione

Un *Macro Requirement* è il documento radice che possiede una **responsabilità macro durevole e autonomamente significativa** necessaria a trattare il problema definito dal framing. Spiega valore e risultato macro, contesto minimo, stakeholder e confine della responsabilità, senza selezionare una soluzione lower-level e senza specificare comportamenti atomici indipendentemente verificabili.

La domanda fondamentale è:

Nel problema di progetto già inquadrato, quale responsabilità macro stabile stiamo governando, quale risultato o valore di livello macro deve contribuire, perché conta e chi coinvolge?

Il termine “concern” può essere usato descrittivamente solo quando identifica una responsabilità macro autonomamente significativa. Non è sufficiente che una proprietà sia importante o trasversale per promuoverla a MR.

4.5.2 Forma semantica

Tabella 4.1: Forma semantica del Macro Requirement.

Concetto	Stato	Funzione
id	richiesto	identità stabile e tracciabilità
title	richiesto	nome conciso comprensibile nel dominio
lifecycle	richiesto	stato di governance corrente/storico
intent	richiesto	scopo, valore e risultato macro desiderato
context	richiesto	background minimo necessario all'interpretazione
stakeholders	richiesto	ruoli beneficiari, coinvolti, governanti o impattati
scope	richiesto semanticamente	confine della responsabilità macro
assumptions	opzionale	fatti trattati come veri per l'intero branch
constraints	opzionale	limiti applicabili all'intero branch
dependsOn	0..* MR	dipendenze macro non gerarchiche

Un campo separato **Objective** non è mantenuto nel core: nei corpus esaminati duplicava l'Intent oppure iniziava a decomporlo in comportamenti lower-level.

4.5.3 Invarianti dell'MR

Gli invarianti della baseline restano:

1. **Root hierarchy:** l'MR non ha parent gerarchico.
2. **Stable identity:** l'identità non dipende dalla forma testuale dell'ID.
3. **Problem anchoring:** l'MR deve essere interpretabile nel problem framing.
4. **Single macro responsibility:** un MR possiede una sola responsabilità macro coerente e autonomamente significativa.
5. **Child narrowing:** Decision e FR discendenti restringono la responsabilità, non introducono scope estraneo.
6. **No solution commitment leakage:** provider, architetture, algoritmi o meccanismi scelti appartengono a Decision salvo che siano intrinseci al dominio del problema.
7. **No FR-level obligation:** comportamenti atomici e operativi appartengono downstream.
8. **Broad domain readability:** il documento è leggibile da stakeholder competenti nel dominio senza richiedere conoscenza dell'implementazione corrente.

9. **Architecture resilience**: sostituire una soluzione lower-level non dovrebbe normalmente richiedere la riscrittura dell'MR.
10. **Temporal stability**: una nuova Decision non rende obsoleto l'MR se la responsabilità macro resta invariata.
11. **Explicit dependency**: relazioni complementari tra MR non devono essere nascoste come pseudo-gerarchia.
12. **Teachability**: title e Intent degli MR devono sostenere una mappa macro comprensibile del progetto.
13. **Analysis enabling, not analysis producing**: l'MR può fornire contesto utile, ma non crea automaticamente categorie o artefatti di una metodologia di analisi.
14. **Projection honesty**: una mappa didattica degli MR non deve essere presentata come DFD o threat model canonico.

Refinement emerso dal controesempio MR-0004

La formulazione “single macro concern” della baseline precedente viene resa più precisa come “single macro responsibility”. Il cambiamento non vieta concern macro autentici; evita che security, privacy, performance, compliance o altri concern trasversali vengano usati come contenitori artificiali quando non possiedono una responsabilità macro autonoma.

4.5.4 Split, merge e dipendenze tra MR

La decomposizione non segue automaticamente l'architettura software. Due sottosistemi non richiedono necessariamente due MR e due responsabilità di dominio non devono essere fuse soltanto perché oggi sono implementate dallo stesso componente. Quando due MR collaborano per uno scopo end-to-end, la collaborazione non implica co-ownership: una dipendenza macro può essere resa esplicita mediante `dependsOn`.

4.5.5 Isolated-MR review: heuristic graph-assisted

Il Macro Project Map può essere usato anche come strumento di quality review. Sia

$$G_{MR} = (V, E_{dependsOn})$$

il grafo dei MacroRequirement e delle relazioni canoniche `dependsOn`. Un nodo m tale che

$$\deg(m) = 0$$

non è automaticamente invalido. Il tool o il reviewer lo segnala però come **review point**.

La domanda principale è:

Se questo MacroRequirement restasse isolato nella Macro Project Map, rappresenterebbe comunque una responsabilità macro autonomamente significativa, oppure sta soprattutto raccogliendo proprietà o constraint che specializzano comportamenti posseduti da altri rami?

Domande di supporto:

1. Rimuovendo il nodo scompare una capability/responsabilità macro del progetto, oppure rimangono le capability e si perdono soprattutto proprietà specializzate?
2. Lo scope dell'MR parla prevalentemente di dati, decisioni o comportamenti posseduti da altri rami?
3. I suoi discendenti plausibili sarebbero soprattutto security/privacy/performance/compliance constraints su FR altrui?
4. L'isolamento dipende invece da una relazione `dependsOn` mancante?
5. Il nodo è stato creato principalmente per dare una “casa” a una metodologia o categoria di analisi?

CANDIDATE - authoring heuristic, non invariante L1

Un MR isolato può essere: (a) una responsabilità macro autonoma valida; (b) un nodo con una dipendenza macro omessa; (c) un concern trasversale classificato troppo in alto. Il warning serve a forzare la domanda, non a imporre connettività artificiale.

4.5.6 Regression example: facial-access senza MR-0004

Il corpus facial-access storico conteneva quattro MR. MR-0001 dipendeva da MR-0002 e MR-0003; MR-0004 - Uso responsabile dei dati biometrici e delle decisioni automatiche era isolato.

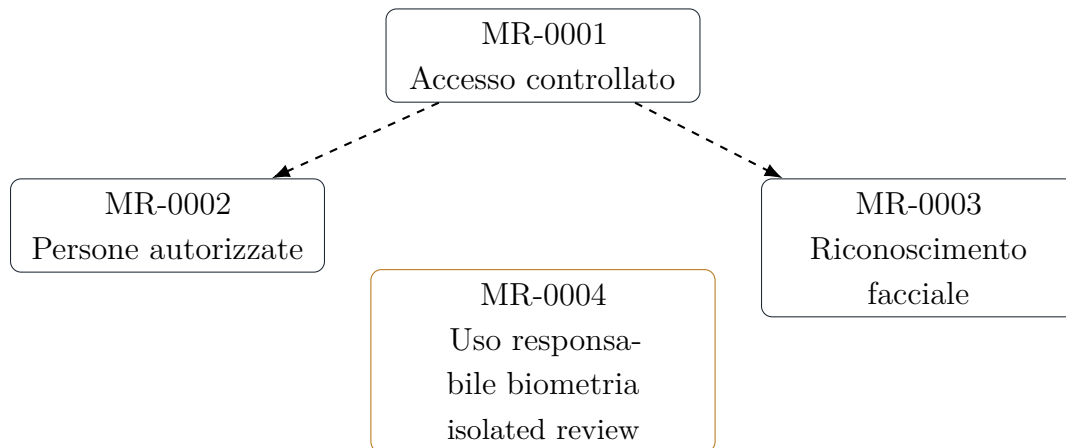


Figura 4.3: Il nodo isolato non è prova di errore; combinato con il contenuto trasversale di MR-0004 ha però motivato la regressione.

Applicando removal e classification test, le tre responsabilità macro restano complete senza MR-0004. I due commitment storici trovano collocazioni più naturali:

- la **limitazione di finalità dei dati biometrici** rafforza i FR che trattano biometria ed è candidata a SpecializedRequirement locale, eventualmente collegato in futuro a una fonte normativa condivisa;
- la **contestabilità/review degli esiti automatici** introduce una responsabilità operativa autonoma e può essere ricollocata sotto MR-0001 mediante una Decision sul principio di review e un FR che esegue il riesame.

CANDIDATE - corpus correction

Per il corpus di studio successivo a S1, MR-0004 viene ritirato come MacroRequirement autonomo. La correzione non cancella i suoi obblighi: li redistribuisce in base alla loro semantica. Questo è un esempio di feedback downstream che migliora la documentazione iniziale.

4.6 Decision

4.6.1 Dalla scelta al commitment significativo

Una *Decision* è un commitment significativo che restringe esattamente un *Macro Requirement*. Registra conoscenza non derivabile che cambia responsibility boundary, strategia, policy, architettura o altro aspetto significativo e produce conseguenze downstream.

Quale commitment significativo restringe questo Macro Requirement, perché il progetto assume questa posizione e quali conseguenze accettiamo?

La forma minima rimane:

```
Decision
|- title
|- context
|- decision
'- consequences
```

Context è locale alla **Decision**; **Decision** contiene una posizione coerente; **Consequences** rende visibili effetti materiali e downstream obligations. Alternative e Rationale possono essere utili in L2 ma non sono campi L1 obbligatori separati.

4.6.2 Decision di responsibility boundary

Prima di scrivere FR occorre rendere esplicito chi possiede un comportamento. Una capability può essere implementata dal progetto oppure consumata da un sistema esterno. La scelta modifica il tipo di FR che il progetto deve possedere.

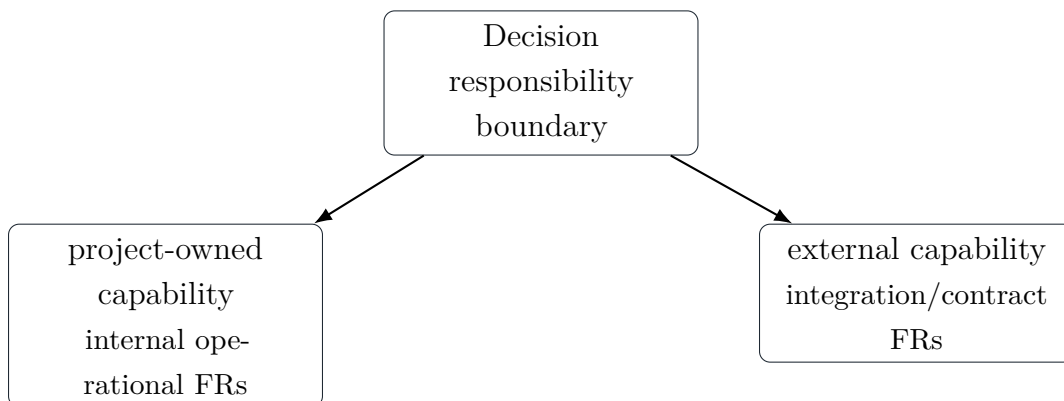


Figura 4.4: Una Decision sul responsibility boundary cambia il branch funzionale downstream.

4.6.3 Necessity/default Decision

La baseline privilegia una gerarchia costante **MR** -> **Decision** -> **FR**. Se non emerge un'alternativa materialmente distinta, una necessity/default Decision è ammessa soltanto dopo review: Context deve spiegare perché lo spazio ammissibile è singleton, il commitment non deve essere tautologico, le Consequences devono essere materiali e il documento deve essere riapribile se cambiano i vincoli.

4.6.4 Split e non ridondanza

Una Decision va divisa quando parti del commitment possono cambiare indipendentemente con conseguenze o trade-off autonomi. Non ogni frase tecnica è una Decision:

tuning, nomi di classi o dettagli incidentali appartengono alla realizzazione se possono cambiare senza modificare il contratto governato.

4.7 Functional Requirement

4.7.1 Definizione operativa

Un *Functional Requirement* è un obbligo operativo governato e indipendentemente valutabile che discende da esattamente una Decision. Esprime comportamento, servizio, transizione o risultato osservabile che il progetto deve fornire nel contesto stabilito dal branch MR/Decision.

Data la Decision parent e una condizione/input applicabile, quale soggetto o capability deve compiere quale azione funzionale su/con quale oggetto o informazione, e quale risultato osservabile o failure behavior deve conseguire?

4.7.2 Gerarchia e ownership

La baseline chiude:

- ogni FR ha esattamente una Decision parent;
- l'MR owner è derivato dal parent della Decision;
- nessuna Decision è figlia di FR;
- un FR può possedere zero o più SpecializedRequirement;
- un nuovo commitment scoperto durante implementazione/review torna sotto l'MR appropriato come Decision, con revisione degli FR interessati.

4.7.3 Forma semantica e normative prose

```
FunctionalRequirement
|- id / lifecycle
|- title
|- functionalObligation
|- functionalClause 1..*
|   |- normativeStatement
|   '- spoReference 1..*
|       |- subject
|       |- predicate
|       '- object
|- parentDecision -> Decision 1
```

```
'- specializedRequirement -> 0..*
```

La prosa normativa rimane primaria. SPO rende espliciti subject, predicate e object riusabili, ma non sostituisce condizioni, correlazione, atomicità o failure semantics.

4.7.4 FunctionalPredicate e parametri

Il Predicate è governato da un metacontratto estendibile, non da un elenco universale congelato. Valori numerici e modalità operative devono essere classificati per semantica: strategia di acquisizione come Decision, target di latenza come Performance/Quality candidate, retention come Governance/Privacy candidate, limiti API come InterfaceContract candidate, tuning come realization/configuration.

4.7.5 Composizione tra MR senza doppia ownership

Un FR consumer può richiedere una capability posseduta da un altro MR senza acquisire un secondo parent. Il target canonico della relazione di consumption rimane deferred alla Base Analysis.

4.8 Specialized Requirement - semantica comune S1

S1 chiude il contratto generale prima di formalizzare *Security Requirement*.

Uno SpecializedRequirement è una specializzazione normativa governata di un singolo FunctionalRequirement che rafforza le condizioni sotto le quali il parent FR è considerato soddisfatto, imponendo un'obbligazione concern-specific che vale insieme all'obbligazione funzionale e non al suo posto.

La forma minima è:

```
SpecializedRequirement [abstract]
|- parentFunctionalRequirement -> FunctionalRequirement 1
'- normativeObligation          -> 1
```

Per F parent e $S_1, \dots, S_n$ applicabili:

$$\text{Effective}(F) = F \wedge S_1 \wedge \dots \wedge S_n.$$

Le regole principali sono:

- ogni SR ha esattamente un FR parent; un FR può avere 0..* SR;

- rimuovere lo SR deve lasciare riconoscibile la funzione del parent FR;
- condizioni necessarie alla normale correttezza funzionale restano nell'FR;
- lo SR può richiedere un'azione positiva subordinata, ma una capability operativa autonoma tende a un FR separato;
- lo SR non prescrive necessariamente il meccanismo o layer di realizzazione;
- lo stesso concern può specializzare più FR mediante SR locali distinti; il riuso della fonte normativa è un problema separato.

Ruolo metodologicamente neutro

SpecializedRequirement è il junction tra documentazione governata e obblighi concern-specific. Una metodologia di analisi non necessita di un proprio MR: può attraversare il progetto e proporre SR sui FR pertinenti. SecurityRequirement è la specializzazione concreta della tesi, non la definizione del concetto generale.

4.9 Regole di authoring end-to-end

La sequenza aggiornata è:

1. **Frame the problem.** Definire problema, boundary e out-of-scope rimuovendo solution vocabulary.
2. **Decompose into MR.** Identificare responsabilità macro stabili, controllando overlap, dipendenze e resilienza.
3. **Review the Macro Project Map.** Segnalare MR isolati e applicare l'Isolated-MR review prima di proseguire: autonomia valida, edge mancante o concern-bucket?
4. **Expose Decisions.** Esplicitare commitment su responsibility boundary, policy, strategia, architettura o contratto significativo.
5. **Write operational FRs.** Tradurre ogni Decision in comportamenti osservabili e indipendentemente valutabili.
6. **Add structured references.** Collegare la prosa normativa a subject, predicate e object governati.
7. **Review cross-branch consumption.** Rendere visibili capability consumate senza trasferire ownership.
8. **Specialize downward.** Aggiungere SR concern-specific senza riscrivere la funzione di base.

Tabella 4.2: Domande di authoring per i livelli documentali.

Livello	Domanda
Problem framing	Quale problema o classe di problemi affrontiamo se rimuoviamo le soluzioni correnti?
MR	Quale responsabilità macro stabile e autonomamente significativa governiamo, quale valore produce e chi coinvolge?
MR graph review	Se l'MR è isolato, resta una responsabilità macro autonoma oppure raccoglie soprattutto proprietà/constraint di altri rami?
Decision	Quale commitment significativo restringe questa responsabilità e quali conseguenze accettiamo?
FR	Dato quel commitment, quale comportamento operativo deve accadere e con quale risultato/failure behavior?
Specialized Requirement	Quale obbligazione concern-specific aggiuntiva deve valere insieme alla funzione senza sostituirla?

4.10 Ruolo del tool nell'authoring

La regolarità della gerarchia consente assistenza prevedibile, ma il tool segue il metamodello e non lo determina. Può:

- mostrare la gerarchia e impedire parentage non ammessi;
- suggerire riferimenti esistenti evitando duplicazioni;
- filtrare Predicate compatibili;
- segnalare incoerenze tra prosa e SPO;
- costruire Macro Project Map e **segnalare MR a grado zero per review semantica**, senza invalidarli automaticamente;
- avviare proposal workflow espliciti quando manca una voce nel registro.

Non deve trasformare automaticamente nomi estratti dalla prosa in semantica canonica, né usare similarity ranking per decidere equivalenza, parentage o ownership.

4.11 Validazione mediante probe iterativi

La costruzione del modello usa esempi, controesempi e regressioni. I primi facial-access probe e il primo holdout order/inventory non sono stati trattati come prova definitiva perché contenevano Decision implicite o responsabilità semplificate. Il corpus warehouse

R3 ha poi sostenuto il parent Decision obbligatorio rendendo esplicito il responsibility boundary.

La regressione MR-0004 aggiunge un tipo diverso di feedback: un livello downstream, SpecializedRequirement, può mostrare che un concern trasversale era stato promosso troppo presto a MacroRequirement. La correzione modifica il minimo owning layer: non altera la semantica dello SR, ma migliora la decomposizione MR e l'autoring question che la verifica.

Lezione metodologica

La documentazione non deve essere perfetta prima dell'analisi. Deve essere plausibile, governata e sufficientemente strutturata da consentire all'analisi e ai probe successivi di scoprire errori di classificazione, gap e nuovi obblighi. Le correzioni devono essere tracciabili e seguite da regressione sui casi già accettati.

4.12 Confine verso Security Requirement e Base Analysis

La closure documentale non equivale alla closure dell'intero DDTA. S1 ha ora chiuso la semantica comune di SpecializedRequirement; la fase successiva può studiare SecurityRequirement come prima specializzazione concreta senza derivarne la semantica da STRIDE.

```
Documentation baseline
MR -> Decision -> FR
    |
    v
SpecializedRequirement common semantics      [S1 CLOSED]
    |
    v
SecurityRequirement metamodel                [next]
    |
    v
Base Analysis / BAE
    |
    v
Analysis Record / Finding common envelope
    |
    v
method-neutral overlay/plugin contract
    |
    v
```

```

STRIDE as first concrete method
  |
  v
accepted Finding -> SecurityRequirement provenance
  |
  v
effective obligation -> design change -> re-analysis

```

Elementi intenzionalmente non chiusi

Restano aperti/deferred: rappresentazione della shared normative source, effective governed context, target canonico della service consumption, lifecycle/change-impact comune, Base Analysis/BAE, Finding/AnalysisRecord, overlay/plugin, STRIDE/STRIDE-AI, controls ed evidence. L'Isolated-MR review non risolve questi problemi e non introduce una generic affects relation.

4.13 Condizioni di riapertura

MR, Decision, FR o SR devono essere riaperti soltanto se una fase successiva mostra un controesempio concreto non rappresentabile senza perdita. In particolare:

1. una specializzazione method-neutral non può rafforzare correttamente un singolo FR;
2. la Base Analysis richiede informazione che il modello di authoring impedisce di esprimere;
3. una metodologia richiede source information ottenibile soltanto contaminando i documenti con categorie method-specific;
4. il layer Decision costante produce un errore semantico ricorrente;
5. service composition richiede ownership multipla incompatibile con il modello;
6. la nuova heuristic sugli MR isolati produce falsi positivi sistematici tali da spingere a relazioni artificiali o alla perdita di macro-responsabilità valide.

Ogni correzione deve modificare il minimo owning layer e regressare i corpus precedenti.

4.14 Conclusioni

La baseline DDTA separa domande che nella documentazione ordinaria tendono a mescolarsi. L'MR stabilisce quale responsabilità macro appartiene al progetto; la Decision stabilisce quale commitment la restringe; l'FR stabilisce quale comportamento operativo

deve conseguire; lo `SpecializedRequirement` aggiunge un'obbligazione concern-specific senza sostituire la funzione.

La regressione di MR-0004 rafforza due aspetti. Primo, la Macro Project Map non serve solo alla teachability: può anche segnalare nodi isolati che meritano review semantica. Secondo, i concern trasversali non necessitano di MacroRequirement dedicati per diventare visibili all'analisi. Il junction naturale rimane `SpecializedRequirement` e la sua specializzazione concreta.

Il metodo rimane deliberatamente pratico: non richiede una documentazione perfetta o completa prima dell'analisi. Richiede documentazione governata sufficiente a rendere esplicite responsabilità, commitment e comportamenti conosciuti; l'analisi successiva può scoprire gap e generare feedback che rientra nel ciclo documentale.

Traceability della revisione S1R1

La revisione è costruita sopra il repository `nballestriero/documentation-driven-threat-analysis` al commit `3eeac1fc972d89282cd2ffd8700e9af0f5b69610`. Documenti sorgente principali:

- `thesis/latex/chapters/04-documentation-authoring-metamodel.tex`;
- `_working/ddta-metamodel-working-package/01-mr/01-metamodel/DDTA_MR_METAMODEL_WORKING.md`;
- `_working/ddta-metamodel-working-package/01-mr/03-example-facial-access/FACIAL_ACCESS_EXAMPLE_MR.md`;
- `02-decision/05-example-facial-access/FACIAL_ACCESS_DECISION_DEMO.md`;
- `03-functional-requirement/02-authoring-guidance/DDTA_AUTHORIZING_RULES_THROUGH_FR_R2.md`;
- `03-functional-requirement/04-closure/DDTA_DOCUMENT_METAMODEL_THROUGH_FR_CLOSURE_R2.md`.

Artefatti companion prodotti durante S1:

- `DDTA_SPECIALIZED_REQUIREMENT_S1_R2.tex/.pdf`;
- `DDTA_FACIAL_ACCESS_CAMERA_S1_STUDY_CORPUS_R2.tex/.pdf`.